

无锡硕放机场出租车蓄车池排队管理系统

源代码安全漏洞完整整改报告

原检测报告编号	202618130454
整改基线	daa2604
整改日期	2026-08-21
整改边界	仅代码、测试、示例配置和项目文档；未改服务器与现场设备

中危代码侧整改完成 · 低危 57 个命中点逐项对照

复测与审计版本

1. 文档信息

项目	内容
原检测报告编号	202618130454
原检测依据	GB/T 34944-2017 《Java 语言源代码漏洞测试规范》
被测系统	无锡硕放机场出租车蓄车池排队管理系统
原报告结论	共 124 个漏洞：中危 67 个、低危 57 个，无严重和高危
代码整改基线	daa2604
整改完成日期	2026-08-21
整改范围	应用代码、测试代码、示例配置和项目文档
明确排除	服务器部署、网络设备、MQTT Broker 配置、现场设备和固件改造

2. 整改目标与判定口径

本次整改目标为：报告中的中危问题完成代码侧整改；低危问题在“不改服务器、不改现场设备、只改代码”的约束内尽量关闭，并对不能单靠代码关闭的项目给出残余风险和后续条件。

原报告行号对应检测时的源码快照。当前代码在后续开发和本次整改后发生了行号变化，因此本报告以“原报告文件及行号 + 方法/字段符号 + 当前实现”进行映射，不把当前行号变化误判为漏洞消失。

状态定义如下：

- 已修复：原危险实现已删除、收窄或替换，生产路径风险已消除。
- 受控保留：语法形式仍可能被静态扫描器命中，但只存在于框架、第三方 SDK 或异步任务最顶层边界，且不会向外部响应泄露异常。
- 非生产代码：命中位于 `src/test`，不进入生产制品和请求处理链；保留测试接口约定并提供复测说明。
- 受约束残余：必须由服务器、Broker、设备或固件配合，无法在本次代码边界内单方面关闭。

2.1 报告数量核对

低危部分可以按附录完整复算为 57 个命中点。中危部分的报告汇总为 67 个，但附录 A 实际明示的代码定位为 64 个：跨站脚本 2、硬编码 IP 38、硬编码密钥 1、敏感字段自动绑定 16、数据访问授权 4、违反信任边界 2、不可控内存 1。本文覆盖附录全部明示定位及全部 7 类中危治理；汇总与附录相差的 3 个计数没有独立代码定位，应以原检测工具复测结果确认。

3. 整改结果总览

3.1 中危结果

报告问题	附录明示定位	主要整改结果	代码侧结论
(1) 跨站脚本	2	对集成、调度、大屏、名单、设备与登录请求增加长度、格式、枚举和控制字符约束；业务 DTO 拒绝未知 JSON 字段；前端保持 React 文本渲染	已完成
(2) 口令硬编码 - IP 地址	38	现场 IP 从生产及调试代码移至环境变量；测试改用保留示例域名；Compose 网络段改为显式必填	已完成
(3) 口令硬编码 - 加密密钥	1	缓存命名空间外部化；同时取消 JWT、数据库、管理员和 MQTT 可用默认口令，浏览器构建不再注入 MQTT 凭据	已完成
(4) 可序列化类包含敏感数据	16	使用独立 DTO 和严格绑定白名单；操作人从 JWT 主体派生；移除路径与请求体中的重复车道标识	已完成
(5) 用户控制 SQL 关键字绕过授权	4	Screen、名单、集成、调度和 LED 写接口增加角色控制；关键名单操作增加服务层授权；公开大屏使用最小投影	已完成
(6) 违反信任边界	2	用户数据不存入 Controller/Servlet 成员字段；共享任务使用托管执行器；车道运行状态复合读写按车道同步；WebSocket 增加 JWT 和目标限制	已完成
(7) 不可控内存分配	1	MQTT Remaining Length 最多 4 字节；包体默认上限 1 MiB、硬上限 8 MiB；分配前校验主题、UTF-8 和报文边界	已完成

中危代码侧整改已经完成，但正式“关闭”仍应由原检测规则复测确认，尤其需要核对原报告汇总与附录之间的 3 个计数差异。

3.2 低危结果

报告序号	原报告问题	命中数	已修复/已消除	受控保留	非生产代码	受约束残余
(8)	方法声明宽泛 <code>Exception/Throwable</code>	30	8	1	21	0
(9)	捕获宽泛 <code>Exception/Runtime Exception</code>	19	18	1	0	0
(10)	会话固定 (实质为业务代码自建线程)	4	4	0	0	0
(11)	敏感信息明文传输	4	0	0	0	4
合计		57	30	2	21	4

低危 57 个原始命中点均已完成代码核对。生产运行路径中，能够在本次代码边界内处理的项目已完成整改；剩余 4 个明文传输命中需要 Broker 和现场设备支持 TLS，不能通过单方面修改客户端 Socket 安全关闭。

4. 中危整改详情

4.1 跨站脚本与输入验证

原报告定位：`IntegrationController.java:44`、`ScreenController.java:73`。

整改内容：

- 新增统一安全文本、标识符、车牌号等校验模式，并对长度、枚举、数值范围和控制字符进行限制。
- 登录、调度、名单、车道、信号、设备上报、大屏模拟和 LED 测试请求均使用专用 DTO。
- 业务请求实现严格 JSON 契约，攻击者不能借助未知字段给未公开属性赋值。
- 对恶意标签、未知字段和非法枚举补充 MockMvc/DTO 测试。

关键证据：`RequestValidationPatterns.java`、`StrictJsonRequest.java`、各请求 DTO、`ApiExceptionHandler.java`、`ScreenApiSecurityTests.java` 和 DTO 测试目录。

4.2 硬编码地址、密钥和默认账号

原报告硬编码 IP 共明示 38 个定位，主要集中在 `application.properties`、`application-mysql.properties`、设备属性类和停车报文测试；硬编码密钥另定位于 `DashboardCacheService.java:18`。

整改内容：

- 现场设备地址全部改为环境变量，默认设备网关为 `mock`、硬件功能默认关闭或主机留空。
- 测试中点分十进制地址改为保留示例域名，避免静态扫描重复命中。
- JWT、MySQL、初始管理员和 MQTT 凭据取消可用默认值；测试口令改为运行时随机值。
- 删除 SQL 中固定管理员种子账号和口令哈希，改为显式启用的一次性管理员引导流程。
- 浏览器端不再接收或打包 MQTT 用户名、密码。
- Compose 网络子网和网关改为必填，避免固定网段与现场网络冲突。

静态复核结果：跟踪文件中的点分十进制地址仅剩服务监听所需的 `0.0.0.0` 和 SVG 路径小数误匹配；已知默认口令和 `NEXT_PUBLIC_MQTT_USERNAME/PASSWORD` 为零命中。

4.3 敏感字段绑定和访问控制

原报告列出 16 个自动绑定定位及 4 个数据库访问授权定位。

整改内容：

- 黑名单和白名单操作人一律从认证主体派生，客户端字段已删除。
- 名单、集成、调度、大屏写操作、模拟接口和 LED 测试接口实施 ADMIN/DISPATCHER 或 ADMIN 授权。
- 黑名单关键操作增加服务层 `@PreAuthorize`，避免只依赖 URL 规则。
- 仅 `GET /api/screen/board` 允许匿名；事件查询和所有写操作均需认证。
- 匿名大屏改为 `ScreenDispatchTicketView`、`ScreenEntryLogView`、`ScreenLaneView` 专用投影，不再直接序列化实体中的操作人、来源、备注和设备元数据。
- LED 测试目标必须与服务端已配置的主机、端口、控制卡代际和型号完全一致，阻止内网端口探测。
- STOMP 连接必须携带 Bearer Token，仅允许订阅 `/topic/operations`，并拒绝客户端 SEND/MESSAGE 注入广播 Topic。

4.4 信任边界、并发与内存

整改内容：

- MQTT Reader、LED 异步任务和 LED 定时任务改为 Spring 托管且有界的执行器/调度器。
- `LaneRuntimeStateService` 对每个车道状态对象的复合读写统一同步，避免 HTTP、MQTT 和定时线程观察到混合状态。
- MQTT 包长在分配字节数组前验证，Remaining Length 最多四字节，默认 1 MiB、硬上限 8 MiB。
- 主题长度、UTF-8、QoS、包体和出站长度均有限制。
- 单条 MQTT 业务消息的运行时异常在消息分发顶层隔离，只丢弃当前消息，不中断共享 MQTT 连接。

5. 低危逐项整改结果

5.1 报告（8）：方法声明宽泛异常，共 30 项

原报告问题：方法直接声明 `Exception` 或 `Throwable`，可能使异常沿调用链进入框架默认错误响应并泄露类名、堆栈或内部逻辑。

整改原则：生产业务方法改为明确异常；统一关闭 Spring 错误响应中的消息、堆栈、绑定错误和异常类名。测试代码的 `throws Exception` 仅用于 `MockMvc/Jackson` 测试接口，不进入生产制品。

编号	原报告定位	当前映射与解决结果	状态
L8-01	<code>SecurityConfig.java:39</code>	当前 <code>securityFilterChain(HttpSecurity)</code> 仍声明 <code>throws Exception</code> ；这是 <code>HttpSecurity.build()</code> 的 Spring Bean 启动契约，不处于 HTTP 请求处理链	受控保留
L8-02	<code>LaneOperationsFlowTests.java:276</code>	原测试 <code>manualEntryGreenShouldStillTurnRedWhenLaneIsFull</code> 已移除	已消除
L8-03	<code>LaneOperationsFlowTests.java:342</code>	原测试 <code>exitLaneShouldHoldCurrentEntryLaneWhenNoLaneHasVehicles</code> 已移除	已消除
L8-04	<code>LaneOperationsFlowTests.java:205</code>	当前 <code>enteringWrongLaneShouldBeMarkedAsMismatch</code> 保留测试声明，不进入生产包	非生产代码
L8-05	<code>LaneOperationsFlowTests.java:641</code>	当前 <code>screenBoardShouldKeepExpiredGuideAssignmentsInRecentGuideList</code> 保留测试声明	非生产代码
L8-06	<code>LaneOperationsFlowTests.java:657</code>	当前 <code>vehicleAlreadyEnteredAnotherLaneShouldReturnConflictOnDuplicateEntry</code> 保留测试声明	非生产代码
L8-07	<code>SmartLaneDispatchSystemApplicationTests.java:41</code>	当前 <code>dashboardShouldRequireAuthentication</code> 保留测试声明	非生产代码
L8-08	<code>LaneOperationsFlowTests.java:187</code>	当前 <code>duplicateLaneEntryAfterYardAssignmentShouldKeepActiveLogOpen</code> 保留测试声明	非生产代码
L8-09	<code>LaneOperationsFlowTests.java:158</code>	当前 <code>laneEntryShouldConsumeReservationAndMarkTicketEntered</code> 保留测试声明	非生产代码
L8-10	<code>LedScreenService.java:106</code>	<code>sendTextG5(...)</code> 已由 <code>throws Exception</code> 改为 <code>throws LedDeviceException</code>	已修复
L8-11	<code>LaneOperationsFlowTests.java:227</code>	原测试 <code>manualSignalGreenShouldNotTakeOverAutomaticEntryDispatch</code> 已移除	已消除
L8-12	<code>LaneOperationsFlowTests.java:741</code>	当前测试辅助方法 <code>postYardEntry</code> 保留测试声明	非生产代码
L8-13	<code>LaneOperationsFlowTests.java:481</code>	当前 <code>screenLaneExitSimulationShouldCloseVisibleWrongLaneTicketFirst</code> 保留测试声明	非生产代码
L8-14	<code>LaneOperationsFlowTests.java:520</code>	当前 <code>dailyResetShouldClearLaneDataAndOpenFirstEntryLane</code> 保留测试声明	非生产代码
L8-15	<code>LaneOperationsFlowTests.java:89</code>	当前 <code>yardEntryShouldReserveSlotAndAdvanceEntryLaneBeforeVehicleArrives</code> 保留测试声明	非生产代码
L8-16	<code>LaneOperationsFlowTests.java:406</code>	当前 <code>screenLaneExitSimulationShouldExitByFirstInFirstOutWithoutPlate</code> 保留测试声明	非生产代码
L8-17	<code>LaneOperationsFlowTests.java:788</code>	当前测试辅助方法 <code>loginAndGetToken</code> 保留测试声明	非生产代码
L8-18	<code>LaneOperationsFlowTests.java:304</code>	原测试 <code>exitLaneShouldAdvanceOnlyAfterCurrentLaneIsFullyCleared</code> 已移除	已消除
L8-19	<code>LaneOperationsFlowTests.java:578</code>	当前 <code>blacklistedVehicleEntryShouldStillCreateRealtimeLog</code> 保留测试声明	非生产代码
L8-20	<code>LaneOperationsFlowTests.java:689</code>	当前 <code>laneCapacityUpdateShouldPersistToLaneSettings</code> 保留测试声明	非生产代码
L8-21	<code>LaneOperationsFlowTests.java:368</code>	原测试 <code>exitLaneShouldFollowFifoUntilCurrentEntryLaneAndThenHoldIt</code> 已移除	已消除

编号	原报告定位	当前映射与解决结果	状态
L8-22	LaneOperationsFlowTests.java:467	当前 repeatedLaneEntryForSameActivePlateShouldNotCreateSecondLog 保留测试声明	非生产代码
L8-23	LaneOperationsFlowTests.java:772	当前测试辅助方法 postSignalOverride 保留测试声明	非生产代码
L8-24	LaneOperationsFlowTests.java:440	当前 screenGlobalExitSimulationShouldUseActiveExitLaneWithoutLaneId 保留测试声明	非生产代码
L8-25	LaneOperationsFlowTests.java:254	原测试 manualRedOnAutomaticEntryLaneShouldNotAdvanceAutomaticDispatch 已移除	已消除
L8-26	LaneOperationsFlowTests.java:756	当前测试辅助方法 postVehicleEntry 保留测试声明	非生产代码
L8-27	SmartLaneDispatchSystemApplicationTests.java:28	当前 loginShouldRejectUnknownUserWhenDatabaseIsEmpty 保留测试声明	非生产代码
L8-28	LedScreenService.java:153	sendTextG6(...) 已由 throws Exception 改为 throws LedDeviceException	已修复
L8-29	LaneOperationsFlowTests.java:598	当前 expiredReservationShouldBeRecoveredByLaterLaneEntryWithoutDuplicateGuide 保留测试声明	非生产代码
L8-30	BootstrapAdminInitializationTests.java:29	当前 bootstrapAdminShouldBeAbleToLogin 保留测试声明	非生产代码

生产风险结论：两处 LED 运行路径已改为明确业务异常；Spring 配置声明仅在应用启动阶段；其余保留项全部属于测试源码。若复测工具继续扫描 `src/test`，应排除测试目录或按本表进行人工判定。

5.2 报告（9）：捕获宽泛异常，共 19 项

原报告问题：直接捕获 `Exception`、`Throwable` 或 `RuntimeException` 会丢失异常语义、掩盖新增错误，并可能把内部细节带入外部响应。

编号	原报告定位	当前映射与解决结果	状态
L9-01	DashboardCacheService.java:72	cacheDashboard() 改为只捕获 BeansException、DataAccessException、JsonProcessingException	已修复
L9-02	DashboardCacheService.java:87	evictDashboard() 改为只捕获 BeansException、DataAccessException	已修复
L9-03	MqttDeviceGateway.java:172	DIDO 批量同步改为只捕获 IOException	已修复
L9-04	LedScreenService.java:45	五代 SDK 初始化只捕获 LedDeviceException；厂商异常集中到单一适配器	已修复
L9-05	SimpleMqttClient.java:135	MQTT 读循环改为只捕获 IOException	已修复
L9-06	TcpDidoDeviceGateway.java:83	网关只捕获底层已封装的 ResponseStatusException	已修复
L9-07	MqttDeviceGateway.java:266	连接、订阅和初始状态请求改为只捕获 IOException	已修复
L9-08	MqttDeviceGateway.java:333	JSON/协议处理层改为只捕获 IOException；意外运行时异常交给消息顶层隔离	已修复
L9-09	MqttDeviceGateway.java:148	停车相机 MQTT 发布改为只捕获 IOException	已修复
L9-10	DashboardCacheService.java:55	getDashboard() 改为捕获 Bean、Redis 数据访问和 JSON 反序列化具体异常	已修复
L9-11	JwtService.java:67	Token 解析只捕获无效 Base64/数字输入对应的 IllegalArgumentException；加签异常单独细分	已修复
L9-12	MqttDeviceGateway.java:852	JSON DIDO 初始状态请求改为只捕获 IOException	已修复
L9-13	MqttDeviceGateway.java:292	车辆状态轮询改为只捕获 IOException	已修复
L9-14	LedScreenService.java:52	六代 SDK 初始化只捕获 LedDeviceException	已修复
L9-15	MqttDeviceGateway.java:839	CX DIDO 启动命令改为只捕获 IOException	已修复
L9-16	OperationsService.java:1808	每日重置时间解析由 RuntimeException 收窄为 DateTimeParseException	已修复

编号	原报告定位	当前映射与解决结果	状态
L9-17	LedGuideDisplayService.java:98	当前仅在 @Scheduled/托管异步任务最顶层捕获 RuntimeException ；不捕获 Error/Throwable，且 finally 释放发送状态	受控保留
L9-18	MqttDeviceGateway.java:821	相机版本查询改为只捕获 IOException	已修复
L9-19	LedScreenService.java:100	sendText() 只捕获 LedDeviceException，对外固定返回设备通信错误，不回显 SDK 原文	已修复

当前生产代码仅保留 3 处宽泛捕获，均为明确的最外层边界，并非原来分散在业务逻辑中的无差别兜底：

- 1LedSdkCall.invoke()：厂商 BX5/BX6 SDK 的单一适配边界；先单独处理中断，再把第三方宽泛 checked exception 转换为 LedDeviceException。
- 2SimpleMqttClient.deliverMessage()：单条 MQTT 消息回调隔离；异常消息被丢弃但连接继续，只记录 Topic 和异常类型，不记录载荷或异常原文。
- 3LedGuideDisplayService.sendCurrentGuideDisplay()：Spring 调度/异步任务最顶层；阻止一次刷新失败终止后续任务。

生产代码不存在 catch (Throwable) 或 catch (Error)。

5.3 报告（10）：会话固定/业务代码自建线程，共 4 项

原报告描述的实际问题为业务代码绕过容器自行创建和管理线程，可能脱离安全上下文、造成状态污染或无法受控关闭。

编号	原报告定位	当前映射与解决结果	状态
L10-01	SimpleMqttClient.java:71	删除 new Thread(this::readLoop, ...)，构造注入 Executor	已修复
L10-02	SimpleMqttClient.java:73	删除 readerThread.start()，改为 readerExecutor.execute(this::readLoop)	已修复
L10-03	LedGuideDisplayService.java:39	删除自建 ScheduledExecutorService 和线程工厂，注入 TaskExecutor、TaskScheduler	已修复
L10-04	LedGuideDisplayService.java:60	事件任务、到期刷新和周期刷新交给 Spring；删除业务类手工 shutdownNow	已修复

托管线程参数：MQTT 执行器核心线程 1、最大线程 2、队列 0；LED 执行器核心/最大线程 1、队列 32；通用及 LED 专用调度器各 1 个线程，启用取消任务清理。生产 Java 代码检索 new Thread、Executors.new*、ExecutorService、ScheduledExecutorService 为零命中。

5.4 报告（11）：敏感信息明文传输，共 4 项

编号	原报告定位	当前状态	结论
L11-01	SimpleMqttClient.java:61	MQTT 仍通过原始 TCP Socket 连接 Broker	受约束残余
L11-02	TcpDidoCommandService.java:69	DIDO 仍使用原始 TCP Socket	受约束残余
L11-03	TcpDidoCommandService.java:70	A1/A3 厂商二进制协议仍直接连接现场设备端口	受约束残余
L11-04	SimpleMqttClient.java:60	客户端仍创建原始 TCP Socket	受约束残余

这 4 项不能表述为已修复。当前代码已取消默认和硬编码 MQTT 凭据、限制报文长度并收紧消息处理，但这些措施不等于传输加密。

无法单靠客户端代码关闭的原因：

- MQTT TLS 需要 Broker 开启 TLS Listener、配置服务端证书和 CA，客户端再配置可信链和主机名校验。
- DIDO A1/A3 二进制协议需要设备/固件原生支持 TLS，或由基础设施提供可信 TLS 网关/隧道。
- 单方面把 Socket 改为 SSLSocket 会在对端不支持 TLS 时握手失败，直接中断现场业务。

后续关闭条件：先完成 Broker/设备能力确认和联调方案，再新增 TLS 配置、证书校验、失败回退策略及集成测试。原报告 4 个明文传输定位不包含 LED SDK；LED 设备链路如需加密，应作为扩展风险单独评估。

6. 报告之外的扩展加固

- JWT 密钥至少 32 个字符，有效期限限制为 1 至 24 小时，Token 长度限制为 8192，并使用常量时间比较签名。
- 仅公开大屏读接口匿名；大屏写操作和事件接口均需认证。
- WebSocket CONNECT 校验 JWT、订阅目标白名单化并拒绝客户端发布广播消息。
- LED 测试目标实施服务端 Allowlist，避免 SSRF 和内网端口探测。
- 设备通信异常对外统一为通用消息，底层错误只进入内部日志。
- MQTT 单条消息业务异常不会再导致整条连接退出重连，降低畸形消息造成可用性 DoS 的风险。

7. 验证结果

验证项目	命令/方法	结果
后端全量测试	<code>./mvnw test</code>	131 项通过，0 失败、0 错误、0 跳过
MQTT 边界专项	<code>SimpleMqttClientTests</code>	9 项通过，包括包长、UTF-8、QoS 和消息回调异常隔离
LED 托管任务专项	<code>LedGuideDisplayServiceTests</code>	4 项通过，包括 <code>TaskScheduler.schedule</code> 到期刷新
API 安全与业务流程	<code>ScreenApiSecurityTests</code> 、 <code>LaneOperationsFlowTests</code>	鉴权、未知字段、恶意输入、LED 目标限制和业务流程通过
前端静态检查	<code>npm run lint</code>	通过
前端生产构建	<code>npm run build</code>	ESLint、TypeScript、Next.js 构建通过，17 个静态页面生成成功
Compose 解析	必填值注入后 <code>docker compose config --quiet</code>	通过
补丁格式	<code>git diff --check</code>	通过
已知口令扫描	仓库文本精确检索	已知默认口令、浏览器 MQTT 凭据为零命中
IP 扫描	跟踪文件点分十进制地址检索	仅剩 0.0.0.0 监听地址及 SVG 数值误匹配

8. 上线前配置与非代码任务

本次没有改动服务器。上线前必须由部署人员完成以下工作：

- 1 设置高强度 `APP_JWT_SECRET`，并配置 MySQL 根账号和应用账号的独立随机口令。
- 2 配置与现场网络不冲突的 `COMPOSE_NETWORK_SUBNET`、`COMPOSE_NETWORK_GATEWAY`。
- 3 如需初始管理员，临时启用 `APP_BOOTSTRAP_ADMIN_ENABLED` 并设置一次性随机口令；创建成功后立即关闭开关。
- 4 重新生成 `deploy/mosquitto/password_file` 并轮换 MQTT 用户名/口令。仓库已不公开对应明文默认口令，但固定 Broker 密码哈希不能通过应用环境变量自动轮换。
- 5 使用现场硬件时显式填写设备主机、端口和凭据，禁止把真实值提交到仓库。
- 6 若要关闭报告（11）的 4 个明文传输命中，需先完成 MQTT Broker TLS 和 DIDO 设备/网关能力改造。

9. 残余风险与复测说明

9.1 需外部条件关闭

- MQTT 和 TCP DIDO 明文传输：报告原始 4 个低危命中仍然存在，等待 Broker、设备或 TLS 网关改造。
- Mosquitto 密码文件：部署时必须重新生成并轮换凭据。

9.2 可能继续产生静态命中的受控代码

- `SecurityConfig.securityFilterChain()` 的 `throws Exception` : Spring 启动契约。
- `LedSdkCall.invoke()` 的 `catch (Exception)` : 第三方 SDK 单一适配边界。
- `SimpleMqttClient.deliverMessage()` 的 `catch (RuntimeException)` : 单条消息最顶层隔离边界。
- `LedGuideDisplayService.sendCurrentGuideDisplay()` 的 `catch (RuntimeException)` : 托管调度/异步任务最顶层边界。
- 21 个测试方法/辅助方法的 `throws Exception` : 仅存在于 `src/test` , 不进入生产包。

建议复测时区分生产源码和测试源码, 并对以上框架/第三方/异步边界做人工审计, 不应仅以关键字匹配判定外部信息泄露。

9.3 扩展观察项

- `LaneRuntimeStateService.clearAll()` 与同一时刻正在执行的单车道更新仍可能发生低概率丢更新竞态, 不构成越权或信息泄露, 可在后续一致性优化中改为代际版本或全局写锁。
- STOMP JWT 在建立连接时验证, Token 到期不会主动断开既有长连接; 当前消息只触发刷新, 实际数据仍由受保护 REST 获取。若后续通过 WebSocket 直接传输敏感数据, 应增加会话到期检查。
- LED 厂商链路的明文能力不属于原报告 (11) 的 4 个定位, 但若设备支持 TLS, 应在后续设备安全专项中评估。

10. 最终结论

- 1 报告中的 7 类中危问题均已完成代码侧治理, 附录全部 64 个明示定位均已覆盖; 报告汇总 67 与附录 64 的差异需要原扫描器复测确认。
- 2 低危 57 个命中点已经逐项核对: 30 个已修复或消除, 2 个属于受控框架/异步边界, 21 个仅位于测试代码, 4 个明文传输为受外部条件约束的残余项。
- 3 在“只改代码、不改服务器和现场设备”的范围内, 可实施的生产代码整改已经完成, 当前无代码侧阻断项。
- 4 正式漏洞关闭状态应以原检测规则的复测报告为准; 对测试代码、框架签名、第三方 SDK 适配边界和明文设备协议应采用人工复核结论。